



Instituto Tecnológico y de Estudios Superiores de Monterrey

Escuela de Ingeniería y Ciencias

Ingeniería en Ciencias de Datos y Matemáticas

Etapas 1 del Reto: Gestor de Identidades

Uso de Álgebras Modernas para Seguridad y Criptografía

Integrantes del equipo:

Carola Vázquez Arjona — A011754562

Iker Alvarez Bandrés — A01282986

Juan Pablo Valdes Cárdenas — A00839013

Andres Vivanco Treviño — A01723358

Juan Fernando González — A01571586

Carlos Eduardo Ramos Martínez — A01286025

Equipo 4 | Grupo 604

Profesores:

Raúl Gómez, Anas Wajid y Alberto F. Martínez

Socio Formador:

Casa Monarca, Ayuda Humanitaria al Migrante, A.B.P.

Monterrey, Nuevo León — 30 de abril de 2023

1. Resumen Ejecutivo

Casa Monarca, Ayuda Humanitaria al Migrante, A.B.P. sufrió una brecha de seguridad que comprometió información personal de su población atendida. El problema central era la ausencia de un sistema estructurado para la gestión de identidades digitales, el control de accesos y la protección documental, lo que dejaba los datos de personas migrantes y solicitantes de asilo expuestos a accesos no autorizados.

El objetivo inicial del reto fue diseñar e implementar un Gestor de Identidades que permitiera a Casa Monarca administrar usuarios, roles y permisos de forma segura, incorporando cifrado de datos sensibles y trazabilidad de operaciones. Se desarrolló una aplicación web modular en PHP con base de datos MySQL, compuesta por tres módulos integrados: gestión de identidades y roles, repositorio documental con sistema de carpetas por área, y firma digital de documentos. El sistema aplica cifrado AES-256 sobre los campos sensibles y registra cada operación en una bitácora de auditoría.

El resultado logrado al cierre de esta etapa es un sistema funcional desplegado en entorno local, con los módulos de identidades y gestión documental completamente operativos y verificados mediante pruebas de endpoint con Postman. El impacto principal es la reducción del riesgo de exposición de datos al eliminar el manejo manual y no cifrado de información de beneficiarios. El estado actual es prototipo en fase de validación con el socio formador.

2. Objetivos vs. Resultados

La siguiente tabla resume el cumplimiento de los objetivos planteados al inicio del reto:

Objetivo	Estado	Observación
Módulo de gestión de identidades y roles (niveles 1–4)	Cumplido	Implementado con modelo de mínimo privilegio
Cifrado de datos sensibles (AES-256)	Cumplido	Aplicado a campos críticos en base de datos
Repositorio documental con carpetas por área	Cumplido	Carpetas globales por área operativas

Bitácora de auditoría por operación	Cumplido	Registra creación, movimiento y eliminación
Firma digital de documentos	Parcial	Funcionalidad disponible; flujo con certificado expirado pendiente
Carpetas personales por colaborador	Pendiente	Requiere confirmación con el socio formador
Cuenta espejo desde frontend (nivel 1)	Pendiente	Lógica de backend implementada; interfaz pendiente

Los objetivos modificados respecto al planteamiento original corresponden a la granularidad de las carpetas: inicialmente se contemplaron carpetas privadas por colaborador, pero por decisión de diseño se optó por carpetas globales por área para simplificar la navegación y evitar fragmentación del repositorio. Esta decisión queda abierta a revisión con el socio.

3. Solución Implementada

El sistema desarrollado es una aplicación web MVC en PHP 8 con base de datos MySQL, estructurada en tres módulos principales. El módulo de identidades gestiona el ciclo de vida de usuarios mediante cuatro niveles de acceso: Administrador (nivel 1), Coordinador (nivel 2), Colaborador (nivel 3) y Consultor (nivel 4). Cada nivel hereda permisos de forma estricta siguiendo el principio de mínimo privilegio, de modo que ningún usuario puede operar fuera de su ámbito de autorización.

El módulo de gestión documental organiza el repositorio por área mediante carpetas compartidas. Los documentos sin carpeta asignada se agrupan en una carpeta virtual denominada 'Sin clasificar', generada dinámicamente sin existencia en base de datos. El módulo expone cuatro endpoints REST (GET /api/carpetas/listar, POST /api/carpetas/crear, POST /api/carpetas/eliminar, POST /api/documentos/mover) con validaciones de integridad y control de acceso por nivel. El módulo de firma digital permite a los niveles 1 y 2 firmar documentos activos; cada firma queda vinculada al documento mediante un campo firma_digital en la tabla correspondiente y registrada en bitácora.

Los usuarios principales del sistema son el personal administrativo y coordinadores de Casa Monarca, quienes gestionan la documentación de beneficiarios. El alcance final de esta etapa cubre la administración completa de identidades y el repositorio documental; la integración con sistemas externos y el módulo de generación de reportes quedan fuera del alcance actual.

4. Impacto de Negocio

Antes de la implementación, la gestión de documentos se realizaba de forma manual y sin controles de acceso diferenciados, lo que implicaba riesgo de exposición y pérdida accidental de información de personas en situación de vulnerabilidad. La solución introduce controles técnicos que mitigan directamente estos riesgos.

Dimensión	Antes	Después
Control de acceso	Sin roles definidos	4 niveles con permisos granulares
Cifrado de datos sensibles	Sin cifrado	AES-256 en campos críticos
Trazabilidad de operaciones	Sin registro	Bitácora completa por operación y usuario
Organización documental	Sin estructura	Carpetas por área con conteo dinámico
Riesgo de pérdida de documentos	Alto (sin validaciones)	Reducido (eliminar carpeta requiere vaciarla)

El impacto más significativo es la reducción del riesgo de exposición de datos personales de migrantes y solicitantes de asilo, una población cuya información es especialmente sensible desde la perspectiva legal y humanitaria. La implementación de cifrado y auditoría también posiciona a Casa Monarca en una trayectoria de cumplimiento con buenas prácticas de protección de datos.

5. Lecciones y Hallazgos

Entre los aspectos que funcionaron bien destaca la decisión de adoptar UUID v4 como identificador primario en todas las entidades, lo que garantiza unicidad sin exponer secuencias predecibles y facilita una eventual migración a arquitectura distribuida. El modelo de carpeta

virtual 'Sin clasificar' generada dinámicamente resultó una solución elegante que evita registros huérfanos y simplifica la migración de datos históricos.

Como área de mejora se identificó la necesidad de definir con mayor precisión los requerimientos del socio antes de tomar decisiones de arquitectura; la incertidumbre sobre carpetas privadas por colaborador implicó diseñar el módulo con flexibilidad adicional no utilizada. En cuanto a riesgos detectados, el flujo de renovación de certificados digitales para el administrador representa una vulnerabilidad operativa: si el certificado del nivel 1 expira, el usuario puede quedar sin acceso a funciones críticas. Este riesgo requiere atención prioritaria en la siguiente iteración.

6. Estado Actual y Próximos Pasos

El sistema se encuentra en estado de prototipo funcional con validación en curso por parte del socio formador. Los módulos de identidades y gestión documental están completos y probados; el módulo de firma digital está operativo pero con el flujo de certificado expirado pendiente de corrección.

Las recomendaciones para la siguiente etapa son las siguientes:

- Resolver el flujo de renovación de certificado del administrador para evitar bloqueos operativos.
- Implementar la cuenta espejo desde el frontend para el nivel 1, completando la funcionalidad ya disponible en backend.
- Validar con el socio la necesidad de carpetas personales por colaborador e implementarlas si se confirma el requerimiento.
- Desarrollar el módulo de generación de reportes y estadísticas de uso para soporte a la toma de decisiones.
- Evaluar el despliegue en un servidor de producción o entorno en la nube con respaldos automatizados y cifrado en tránsito (HTTPS).
- Elaborar el manual de usuario con capturas de pantalla paso a paso para facilitar la adopción por parte del personal de Casa Monarca.

7. Referencias

- Justinha. (s. f.). Microsoft Entra ID documentation. Microsoft Learn. <https://learn.microsoft.com/en-us/entra/identity/>
- rwestMSFT. (s. f.). Transparent Data Encryption (TDE) - SQL Server. Microsoft Learn. <https://learn.microsoft.com/en-us/sql/relational-databases/security/encryption/transparent-data-encryption>
- National Institute of Standards and Technology. (2023). Advanced Encryption Standard (AES) (FIPS PUB 197, Update 1). <https://doi.org/10.6028/nist.fips.197-upd1>
- Msmbaldwin. (s. f.). Azure Key Vault Overview. Microsoft Learn. <https://learn.microsoft.com/en-us/azure/key-vault/general/overview>